

Cloud Security Assessment Report

Target: **IIIT Nagpur**

Account ID: 710215922764

Region: us-east-1

Assessment Date: 2026-05-09

Report Generated: 2026-05-09 11:37 UTC

Assessor: Rishikesh

Classification: CONFIDENTIAL

1. Executive Summary

An automated cloud security assessment was conducted against the target AWS account using the AZTCSE framework. The assessment identified **26 total findings**, including **2 CRITICAL**, **6 HIGH**, **0 MEDIUM**, and **2 LOW** severity issues. A total of **10 attack paths** were confirmed against the live AWS environment.

Overall Risk Score

0.55 / 1.00 - HIGH

Severity	Count	Status
[CRITICAL]	2	Immediate action required
[HIGH]	6	Remediate within 7 days
[MEDIUM]	0	Remediate within 30 days
[LOW]	2	Remediate within 90 days

2. Attack Surface & Confirmed Paths

2.1 Nation-State APT

Exploit Score	0.77	Time to Compromise	45.2h	Detection Likelihood	9%
---------------	------	--------------------	-------	----------------------	----

Kill Chain Steps:

Phase	Technique	Target	Success%	Detect Risk
Reconnaissance	OSINT + LinkedIn scraping for AWS account IDs	External	99%	1%
Initial Access	Spear-phishing → stolen console credentials	IAM User	75%	11%
Execution	Lambda function deployment with reverse shell	Lambda	70%	14%
Persistence	Hidden IAM backdoor user + long-lived access key	IAM	95%	7%
Defense Evasion	CloudTrail log deletion + GuardDuty suppression	CloudTrail	80%	4%
Credential Access	Secrets Manager bulk dump	Secrets	90%	6%
Lateral Movement	Cross-account role assumption via weak trust	IAM Role	65%	9%
Collection	S3 bucket enumeration + selective data staging	S3	95%	4%
Exfiltration	Encrypted S3 replication to attacker account	S3	88%	2%
Impact	Persistent access maintained; data sold/exploited	All	100%	0%

AWS-Confirmed Vulnerabilities:

- MFA not enabled: aztcse-lab-user, aztcse-scanner, db-service-account

Recommendations:

- Enable MFA for all IAM users immediately (CRITICAL)
- Deploy GuardDuty + Security Hub + AWS Detective for APT detection

2.2 Ransomware Group

Exploit Score	0.5	Time to Compromise	0.8h	Detection Likelihood	69%
---------------	-----	--------------------	------	----------------------	-----

Kill Chain Steps:

Phase	Technique	Target	Success%	Detect Risk
Reconnaissance	Shodan scan for exposed AWS endpoints	External	99%	5%
Initial Access	Credential stuffing via leaked access keys (GitHub)	IAM User	80%	36%
Execution	Pacu framework automated exploitation	EC2/Lambda	75%	55%

Persistence	Admin IAM user created for ransom negotiation	IAM	80%	46%
Defense Evasion	CloudTrail disabled + GuardDuty detector deleted	CloudTrail	65%	64%
Impact	S3 mass re-encryption + RDS snapshot deletion	S3/RDS	85%	86%
Impact	Ransom note uploaded to public S3 bucket	S3	100%	91%

AWS-Confirmed Vulnerabilities:

- **MFA not enabled: aztcse-lab-user, aztcse-scanner, db-service-account**

Recommendations:

- Enable MFA for all IAM users immediately (CRITICAL)
- Enable S3 Versioning + Object Lock; use AWS Backup for RDS

2.3 Malicious Insider

Exploit Score	0.73	Time to Compromise	11.8h	Detection Likelihood	21%
---------------	-------------	--------------------	--------------	----------------------	------------

Kill Chain Steps:

Phase	Technique	Target	Success%	Detect Risk
Reconnaissance	Internal Confluence/Slack data mining	Internal	99%	4%
Initial Access	Console login with own valid credentials	Console	100%	2%
Collection	Bulk S3 download via AWS CLI with own permissions	S3	95%	15%
Credential Access	Self-create additional IAM access key	IAM	100%	19%
Exfiltration	RDS snapshot exported to personal AWS account	RDS	80%	23%
Lateral Movement	Assume roles granted by overly permissive policies	IAM Role	70%	15%
Defense Evasion	Delete CloudTrail events via console	CloudTrail	60%	30%

AWS-Confirmed Vulnerabilities:

- **MFA not enabled: aztcse-lab-user, aztcse-scanner, db-service-account**

Recommendations:

- Enable MFA for all IAM users immediately (CRITICAL)

2.4 Script Kiddie

Exploit Score	0.14	Time to Compromise	0.1h	Detection Likelihood	91%
---------------	-------------	--------------------	-------------	----------------------	------------

Kill Chain Steps:

Phase	Technique	Target	Success%	Detect Risk
Reconnaissance	ScoutSuite / Pacu auto-scan	External	99%	78%
Initial Access	Open S3 bucket access / brute force login	S3/Console	50%	87%
Execution	EC2 crypto-miner deployment (UserData script)	EC2	60%	92%
Impact	Resource abuse for crypto mining	EC2	70%	96%

AWS-Confirmed Vulnerabilities:

- **MFA not enabled: aztcse-lab-user, aztcse-scanner, db-service-account**

Recommendations:

→ Enable MFA for all IAM users immediately (CRITICAL)

2.5 Supply Chain Attacker

Exploit Score **0.6** Time to Compromise **60.0h** Detection Likelihood **8%**

Kill Chain Steps:

Phase	Technique	Target	Success%	Detect Risk
Reconnaissance	Open-source dependency graph analysis	External	99%	1%
Initial Access	Malicious Lambda layer published to public registry	Lambda	70%	4%
Execution	Lambda env var exfiltration on next invocation	Lambda	85%	7%
Persistence	Backdoor baked into ECR base image	ECR	80%	6%
Credential Access	CI/CD env secrets exfiltrated via CodeBuild logs	CodeBuild	75%	9%
Lateral Movement	Use stolen creds to pivot to production account	IAM	75%	11%
Collection	Bulk secret export from Secrets Manager	Secrets	88%	7%
Exfiltration	Data exfil via DNS tunneling from Lambda	Lambda	72%	4%

AWS-Confirmed Vulnerabilities:

- **MFA not enabled: aztcse-lab-user, aztcse-scanner, db-service-account**

Recommendations:

→ Enable MFA for all IAM users immediately (CRITICAL)

→ Pin Lambda layer versions; enable ECR image scanning; use CodeArtifact

2.6 Nation-State APT

Exploit Score

0.77

Time to Compromise

45.2h

Detection Likelihood

9%**Kill Chain Steps:**

Phase	Technique	Target	Success%	Detect Risk
Reconnaissance	OSINT + LinkedIn scraping for AWS account IDs	External	99%	1%
Initial Access	Spear-phishing → stolen console credentials	IAM User	75%	11%
Execution	Lambda function deployment with reverse shell	Lambda	70%	14%
Persistence	Hidden IAM backdoor user + long-lived access key	IAM	95%	7%
Defense Evasion	CloudTrail log deletion + GuardDuty suppression	CloudTrail	80%	4%
Credential Access	Secrets Manager bulk dump	Secrets	90%	6%
Lateral Movement	Cross-account role assumption via weak trust	IAM Role	65%	9%
Collection	S3 bucket enumeration + selective data staging	S3	95%	4%
Exfiltration	Encrypted S3 replication to attacker account	S3	88%	2%
Impact	Persistent access maintained; data sold/exploited	All	100%	0%

AWS-Confirmed Vulnerabilities:

- **MFA not enabled: aztcse-lab-user, aztcse-scanner, db-service-account**

Recommendations:

- Enable MFA for all IAM users immediately (CRITICAL)
- Deploy GuardDuty + Security Hub + AWS Detective for APT detection

2.7 Ransomware Group

Exploit Score

0.5

Time to Compromise

0.8h

Detection Likelihood

69%**Kill Chain Steps:**

Phase	Technique	Target	Success%	Detect Risk
Reconnaissance	Shodan scan for exposed AWS endpoints	External	99%	5%
Initial Access	Credential stuffing via leaked access keys (GitHub)	IAM User	80%	36%
Execution	Pacu framework automated exploitation	EC2/Lambda	75%	55%
Persistence	Admin IAM user created for ransom negotiation	IAM	80%	46%
Defense Evasion	CloudTrail disabled + GuardDuty detector deleted	CloudTrail	65%	64%
Impact	S3 mass re-encryption + RDS snapshot deletion	S3/RDS	85%	86%

Impact	Ransom note uploaded to public S3 bucket	S3	100%	91%
--------	--	----	------	-----

AWS-Confirmed Vulnerabilities:

- **MFA not enabled: aztcse-lab-user, aztcse-scanner, db-service-account**

Recommendations:

- Enable MFA for all IAM users immediately (CRITICAL)
- Enable S3 Versioning + Object Lock; use AWS Backup for RDS

2.8 Malicious Insider

Exploit Score	0.73	Time to Compromise	11.8h	Detection Likelihood	21%
---------------	-------------	--------------------	--------------	----------------------	------------

Kill Chain Steps:

Phase	Technique	Target	Success%	Detect Risk
Reconnaissance	Internal Confluence/Slack data mining	Internal	99%	4%
Initial Access	Console login with own valid credentials	Console	100%	2%
Collection	Bulk S3 download via AWS CLI with own permissions	S3	95%	15%
Credential Access	Self-create additional IAM access key	IAM	100%	19%
Exfiltration	RDS snapshot exported to personal AWS account	RDS	80%	23%
Lateral Movement	Assume roles granted by overly permissive policies	IAM Role	70%	15%
Defense Evasion	Delete CloudTrail events via console	CloudTrail	60%	30%

AWS-Confirmed Vulnerabilities:

- **MFA not enabled: aztcse-lab-user, aztcse-scanner, db-service-account**

Recommendations:

- Enable MFA for all IAM users immediately (CRITICAL)

2.9 Script Kiddie

Exploit Score	0.14	Time to Compromise	0.1h	Detection Likelihood	91%
---------------	-------------	--------------------	-------------	----------------------	------------

Kill Chain Steps:

Phase	Technique	Target	Success%	Detect Risk
Reconnaissance	ScoutSuite / Pacu auto-scan	External	99%	78%

Initial Access	Open S3 bucket access / brute force login	S3/Console	50%	87%
Execution	EC2 crypto-miner deployment (UserData script)	EC2	60%	92%
Impact	Resource abuse for crypto mining	EC2	70%	96%

AWS-Confirmed Vulnerabilities:

- **MFA not enabled: aztcse-lab-user, aztcse-scanner, db-service-account**

Recommendations:

→ Enable MFA for all IAM users immediately (CRITICAL)

2.10 Supply Chain Attacker

Exploit Score **0.6** Time to Compromise **60.0h** Detection Likelihood **8%**

Kill Chain Steps:

Phase	Technique	Target	Success%	Detect Risk
Reconnaissance	Open-source dependency graph analysis	External	99%	1%
Initial Access	Malicious Lambda layer published to public registry	Lambda	70%	4%
Execution	Lambda env var exfiltration on next invocation	Lambda	85%	7%
Persistence	Backdoor baked into ECR base image	ECR	80%	6%
Credential Access	CI/CD env secrets exfiltrated via CodeBuild logs	CodeBuild	75%	9%
Lateral Movement	Use stolen creds to pivot to production account	IAM	75%	11%
Collection	Bulk secret export from Secrets Manager	Secrets	88%	7%
Exfiltration	Data exfil via DNS tunneling from Lambda	Lambda	72%	4%

AWS-Confirmed Vulnerabilities:

- **MFA not enabled: aztcse-lab-user, aztcse-scanner, db-service-account**

Recommendations:

→ Enable MFA for all IAM users immediately (CRITICAL)

→ Pin Lambda layer versions; enable ECR image scanning; use CodeArtifact

3. Remediation Roadmap

[CRITICAL] — Immediate ($\leq 48h$)

#	Action	AWS Service
1	Enable MFA for all IAM users immediately (CRITICAL)	IAM

[HIGH] — Short-term (≤ 7 days)

#	Action	AWS Service
1	Deploy GuardDuty + Security Hub + AWS Detective for APT detection	GuardDuty

[MEDIUM] — Mid-term (≤ 30 days)

#	Action	AWS Service
1	Enable S3 Versioning + Object Lock; use AWS Backup for RDS	S3
2	Pin Lambda layer versions; enable ECR image scanning; use CodeArtifact	Multi-service

Appendix: Raw Evidence Files

The following JSON evidence files were generated during the assessment and are referenced in this report:

- `attack_sim_extended_20260509_113710.json`
- `attack_sim_extended_20260509_113142.json`
- `attack_sim_advanced_20260509_170656.json`
- `attack_sim_advanced_20260509_164711.json`